

# INCIDENT RESPONSE REPORT

Linux worker compromise — vbox (192.168.4.22)

|                |                                                     |
|----------------|-----------------------------------------------------|
| Evidence       | uac-vbox-linux-20260324234043.tar.gz                |
| System         | Debian 13.4 (Trixie) — kernel 6.12.74+deb13+1-amd64 |
| Hostname       | vbox                                                |
| IP             | 192.168.4.22                                        |
| Jump host      | 192.168.4.35                                        |
| Attacker C2    | 192.168.5.95                                        |
| Collection     | 2026-03-24 23:38–23:39 UTC (19:38–19:39 EDT)        |
| Classification | Internal Use                                        |

## 1. Short answer

The system is compromised. A cryptominer disguised as the system utility *top* has been running since roughly 7:34 PM EDT on March 24, burning all available CPU. A userland rootkit loaded via **/etc/ld.so.preload** hides it and four other attacker processes from every monitoring tool on the box. An outbound SSH tunnel carries mining traffic to 192.168.5.95. The SOC alerts about unencrypted port-22 traffic and missing CPU consumers both trace back to the same intrusion.

## 2. Timeline of the attack

The machine was built and first booted the same day it was compromised. All times are EDT (UTC-4), the system's local timezone.

| Time (EDT)     | Event                                                                                                                        |
|----------------|------------------------------------------------------------------------------------------------------------------------------|
| 11:53 AM       | First boot. Hal does local setup (console + direct SSH, no remote host).                                                     |
| 12:02–12:56 PM | First remote session from jump host (192.168.4.35). System crashes at 12:56, likely from a failed rootkit installation.      |
| 1:06–1:14 PM   | Reboot, then a 7-minute session.                                                                                             |
| 2:54–6:15 PM   | Long session from the jump host. Root SSH'd to 192.168.5.95 during this window — /root/.ssh/known_hosts updated              |
| 6:03–6:15 PM   | Second concurrent window on pts/3 — likely testing miner or rootkit.                                                         |
| 6:15 PM        | System crashes again (failed rootkit load).                                                                                  |
| 7:16–7:21 PM   | Boot and crash. Same pattern.                                                                                                |
| 7:21:56 PM     | Final boot (system still running at collection time).                                                                        |
| 7:22–7:27 PM   | Five-minute session. Rootkit planted:<br>7:24:51 PM — libymv.so.3 written to disk<br>7:25:09 PM — /etc/ld.so.preload updated |
| 7:34 PM        | Worker logs in. Miner and SSH tunnel launched, all hidden by the now-active rootkit.                                         |
| 7:38 PM        | UAC collection begins. Rootkit still running.                                                                                |

## 3. Answering the SOC's three questions

### 3a. Why unencrypted traffic on port 22?

The NMS caught the string `python3 -c 'import pty; pty.spawn("/bin/bash")'` in port-22 traffic. That command upgrades a dumb shell to a proper interactive terminal — a standard step after an attacker lands an initial shell. The traffic was visible to the NMS because the attacker's early-stage reverse shell to 192.168.5.95 ran over port 22 using a plaintext protocol before the proper SSH tunnel was established.

The processes behind this are PIDs 939, 940, and 941, all hidden by the rootkit. PID 940 (python3) is the PTY upgrade. PID 941 (bash) is the shell that resulted. Their stdin/stdout both point at the SSH socket for the inbound connection from 192.168.4.35, confirmed by Volatility sockstat analysis of the memory dump.

### 3b. What is burning the CPU?

PID 977, a binary named **top** running from /dev/shm/kit/top (deleted from disk after launch). It accounts for the full 97.7% user-space CPU load. The binary was erased from disk immediately after execution — a standard

trick to leave no file on disk for scanners to find — but the process kept running in memory.

Memory string at offset 106449040 gives the command line exactly: `top -o 127.0.0.1:3333 -B`. The `-o` flag is the pool address. Port 3333 is a local SSH port forward — see the tunnel section below. PID 977 has worker threads named `libuv-worker`, consistent with XMRig (a Monero CPU miner that uses libuv for async I/O).

### 3c. Why can't the SOC see any of this?

A userland rootkit is hiding the processes. It works by injecting a malicious shared library into every process on the system via `/etc/ld.so.preload`. That file tells the dynamic linker to load the specified library before anything else. The library hooks system calls related to process and file listing — functions that tools like `ps`, `top`, `ls`, and `ss` rely on — and silently removes the attacker's PIDs from results.

| Item                  | Value                                                               |
|-----------------------|---------------------------------------------------------------------|
| Library               | <code>/usr/lib/x86_64-linux-gnu/libymv.so.3</code>                  |
| Preload entry         | <code>/etc/ld.so.preload → /lib/x86_64-linux-gnu/libymv.so.3</code> |
| MD5                   | <code>e2c2e24aa54c08b722a03f39b78c95dc</code>                       |
| SHA1                  | <code>0fd709f09c073df274e272aabcabe3e0f3487f9e</code>               |
| Size                  | 24,024 bytes                                                        |
| Written to disk       | 2026-03-24 23:24:51 UTC (19:24:51 EDT)                              |
| ld.so.preload updated | 2026-03-24 23:25:09 UTC (19:25:09 EDT)                              |

The name 'ymv' appears in both the library filename and the SSH config alias used by the attacker's tunnel: `ssh -F config ymv` (found in memory strings at offset 106448976). It's the attacker's campaign tag. The SSH config file was at `/dev/shm/kit/config` and was deleted along with the rest of the staging directory.

### Hidden processes

| PID | Binary                     | Role                                                           |
|-----|----------------------------|----------------------------------------------------------------|
| 939 | <code>sh (dash)</code>     | Initial shell after the attacker landed                        |
| 940 | <code>python3.13</code>    | PTY upgrade — the string the NMS caught                        |
| 941 | <code>bash</code>          | Interactive attacker shell                                     |
| 975 | <code>ssh</code>           | Outbound tunnel to 192.168.5.95:22, local forward on port 3333 |
| 977 | <code>top (deleted)</code> | XMRig cryptominer — the CPU consumer                           |

All five processes carry GID 7823 on their `/proc` entries. That GID has no entry in `/etc/group`. The attacker likely created an account or group with this ID and deleted it afterward, but left behind files still owned by the orphaned GID.

## 4. How the mining traffic flows

The miner connects to `localhost:3333`. PID 975 (`ssh`) listens on that port and forwards traffic through an outbound SSH session to 192.168.5.95:22. From there it reaches whatever mining pool the attacker is using. The actual pool address is not visible in this collection — it terminates at the attacker's machine.

```
miner (PID 977) → localhost:59182 → localhost:3333 [SSH LocalForward – PID 975] →  
192.168.5.95:22 (attacker C2) → mining pool (unknown)
```

Mining traffic leaves the box over port 22 as SSH — exactly what the NMS flagged as suspicious. The SOC description of 'unencrypted traffic on port 22' likely refers to the initial plaintext reverse shell connection that preceded this tunnel setup.

## 5. The [psimon] processes

Three processes appear in ps as [psimon] (PIDs 374, 750, 1012). They have zero VSZ and RSS, formatted like kernel threads. 'psimon' is not a real kernel thread name. They may be decoy entries created by the rootkit to confuse process analysis, or artifacts of an earlier installation attempt. They warrant follow-up but are not the primary concern here.

The kernel taint value is 4 (out-of-tree module). This is fully explained by the vboxguest VirtualBox module. There is no kernel-level rootkit in the loaded module list — the rootkit here is entirely userspace.

## 6. Indicators of compromise

| Type              | Value                                       |
|-------------------|---------------------------------------------|
| Rootkit library   | /usr/lib/x86_64-linux-gnu/libymv.so.3       |
| MD5               | e2c2e24aa54c08b722a03f39b78c95dc            |
| SHA1              | 0fd709f09c073df274e272aabcabe3e0f3487f9e    |
| Preload file      | /etc/ld.so.preload (contains rootkit path)  |
| Miner binary      | /dev/shm/kit/top (deleted — in-memory only) |
| Miner command     | top -o 127.0.0.1:3333 -B                    |
| Staging directory | /dev/shm/kit/ (deleted)                     |
| SSH config        | /dev/shm/kit/config (deleted)               |
| C2 address        | 192.168.5.95:22                             |
| SSH host alias    | ymv                                         |
| Local proxy port  | 127.0.0.1:3333                              |
| Orphan GID        | 7823 (not in /etc/group)                    |

## 7. What to do

Don't trust tool output from the running system. The rootkit is still active and will manipulate whatever you run on it.

**Network-quarantine now.** Cut the machine's network access before doing anything else. The C2 tunnel is live.

**Wipe and rebuild.** The compromise is deep enough — rootkit in ld.so.preload, miner running in memory, active C2 — that trying to disinfect the running system is not worth the risk. Rebuild from a known-good image and restore data from backup after verifying it.

**Investigate 192.168.5.95.** If this IP is internal, you likely have a bigger problem elsewhere. If external, block it and search firewall logs for other internal hosts that have connected to it.

|                                            |                                                                                                                                                      |
|--------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Audit the jump host (192.168.4.35).</b> | All attacker traffic went through it. It may also be compromised.                                                                                    |
| <b>Fix the worker account.</b>             | NOPASSWD sudo on a shared account is a misconfiguration regardless of this incident. Rotate credentials, enforce MFA, and eliminate shared accounts. |
| <b>Hunt libymv.so.3 across the fleet.</b>  | Search for the library path, any /etc/ld.so.preload entries, GID 7823 file ownership, and outbound connections to 192.168.5.95.                      |

Evidence collected using UAC (Unix Artifact Collector). Memory analysis via Volatility 3.2.7. Timestamps cross-referenced against bodyfile and live-response artifacts. All epoch values converted from UTC; system local timezone is EDT (UTC-4). Distribution restricted to IR/Threat team and named stakeholders.